

RETEST ETHICAL HACKING

Proyecto: DT.Claro.Miniprogram.TuLlave_Mass | Fecha: 21/05/2026

Target API: https://urs.qa.vettica.co | Total hallazgos: 16
Crítica: 4 | Alta: 3 | Media: 3 | Baja: 6
Priorización: 16 hallazgos — 4 críticos
- Priorizar remediación de hallazgos CRITICAL (secretos, inyección, auth rota).
- Planificar corrección de hallazgos HIGH (transporte, headers, exposición).
Extensiones analizadas: .acss, .axml, .js, .json

Endpoints analizados

#	Metodo	Path	Hallazgos
1	GET	/card/valid/	9
2	GET	/card/getBalance/	9
3	GET	/card/getInformation/	9

#	Vulnerabilidad	Riesgo	CVSS	Estado	Endpoint
1	Hardcoded Credentials	CRITICAL	9.0	Persistente	scan-98-trivy.json:29
2	Hardcoded Credentials	CRITICAL	9.0	Persistente	scan-99-trivy.json:29
3	Hardcoded Credentials	CRITICAL	9.0	Persistente	main/ui/pages/pseForm/pseForm.js:222
4	Servidor acepta JWT con alg=none (firma bypasseada)	CRITICAL	9.0	Persistente	https://urs.qa.vettica.co/
5	[Semgrep] detected-jwt-token	HIGH	8.0	Persistente	main\utils\merchant-config.js:14
6	[Semgrep] detected-jwt-token	HIGH	8.0	Persistente	main\utils\merchant-config.js:16
7	[Semgrep] detected-jwt-token	HIGH	8.0	Persistente	main\utils\merchant-config.js:18
8	Sensitive Data in Logs	MEDIUM	6.0	Persistente	main/ui/pages/rechargeAmount/rechargeAmount.js:194
9	Falta cabecera Strict-Transport-Security (HSTS)	MEDIUM	6.0	Persistente	https://urs.qa.vettica.co
10	JWT TTL excesivo (2160h)	MEDIUM	6.0	Persistente	<dynamic:jwt>
11	Falta X-Content-Type-Options	LOW	3.0	Persistente	https://urs.qa.vettica.co/
12	Falta Referrer-Policy	LOW	3.0	Persistente	https://urs.qa.vettica.co/
13	Validación manual requerida: BOLA/IDOR por objeto	LOW	3.0	Persistente	https://urs.qa.vettica.co
14	Validación manual requerida: BFLA por rol	LOW	3.0	Persistente	https://urs.qa.vettica.co
15	Validación manual requerida: Mass Assignment	LOW	3.0	Persistente	https://urs.qa.vettica.co
16	Validación manual requerida: JWT claims/TTL/revocación	LOW	3.0	Persistente	https://urs.qa.vettica.co

Detalle tecnico

1. Hardcoded Credentials (CRITICAL)

Estado: Persistente | CWE: CWE-798
Endpoint: scan-98-trivy.json:29
Descripcion: Coincidencia de patrón HARDCODED_CREDENTIALS en scan-98-trivy.json:29.
Recomendacion: No almacenes contraseñas en código; usa gestores de secretos.

2. Hardcoded Credentials (CRITICAL)

Estado: Persistente | CWE: CWE-798

Endpoint: scan-99-trivy.json:29

Descripción: Coincidencia de patrón HARDCODED_CREDENTIALS en scan-99-trivy.json:29.

Recomendación: No almacenes contraseñas en código; usa gestores de secretos.

3. Hardcoded Credentials (CRITICAL)

Estado: Persistente | CWE: CWE-798

Endpoint: main/ui/pages/pseForm/pseForm.js:222

Descripción: Coincidencia de patrón HARDCODED_CREDENTIALS en main/ui/pages/pseForm/pseForm.js:222.

Recomendación: No almacenes contraseñas en código; usa gestores de secretos.

4. Servidor acepta JWT con alg=none (firma bypasada) (CRITICAL)

Estado: Persistente | CWE: CWE-345

Endpoint: https://urs.qa.vettica.co/

Descripción: El endpoint https://urs.qa.vettica.co/ respondió 404 a un token forjado con alg=none. Cualquier usuario puede suplantar a otro sin conocer la clave secreta.

Recomendación: Valida alg en allowlist estricta (['HS256','RS256']). Rechaza alg:none explícitamente.

5. [Semgrep] detected-jwt-token (HIGH)

Estado: Persistente | CWE: CWE-321: USE OF HARD-CODED CRYPTOGRAPHIC KEY

Endpoint: main\utils\merchant-config.js:14

Descripción: JWT token detected

Recomendación: Corregir según la regla Semgrep indicada; revisar documentación del lenguaje y OWASP.

6. [Semgrep] detected-jwt-token (HIGH)

Estado: Persistente | CWE: CWE-321: USE OF HARD-CODED CRYPTOGRAPHIC KEY

Endpoint: main\utils\merchant-config.js:16

Descripción: JWT token detected

Recomendación: Corregir según la regla Semgrep indicada; revisar documentación del lenguaje y OWASP.

7. [Semgrep] detected-jwt-token (HIGH)

Estado: Persistente | CWE: CWE-321: USE OF HARD-CODED CRYPTOGRAPHIC KEY

Endpoint: main\utils\merchant-config.js:18

Descripción: JWT token detected

Recomendación: Corregir según la regla Semgrep indicada; revisar documentación del lenguaje y OWASP.

8. Sensitive Data in Logs (MEDIUM)

Estado: Persistente | CWE: CWE-532

Endpoint: main/ui/pages/rechargeAmount/rechargeAmount.js:194

Descripción: Coincidencia de patrón SENSITIVE_DATA_LOGGING en main/ui/pages/rechargeAmount/rechargeAmount.js:194.

Recomendación: No registres contraseñas ni tokens; usa enmascaramiento o niveles de log seguros.

9. Falta cabecera Strict-Transport-Security (HSTS) (MEDIUM)

Estado: Persistente | CWE: CWE-319

Endpoint: https://urs.qa.vettica.co

Descripción: No se detectó HSTS en la respuesta; los clientes no reciben la política de forzar HTTPS.

Recomendación: Añade HSTS con un max-age adecuado (y preload si aplica) en el balanceador o API gateway.

10. JWT TTL excesivo (2160h) (MEDIUM)

Estado: Persistente | CWE: CWE-613

Endpoint: <dynamic:jwt>

Descripción: El token tiene una vida útil de 2160 horas, superior al límite recomendado de 24h.

Recomendación: Usa access tokens de vida corta ($\leq 1h$) y refresh tokens separados con rotación.

11. Falta X-Content-Type-Options (LOW)

Estado: Persistente | CWE: CWE-16

Endpoint: <https://urs.qa.vettica.co/>

Descripción: La respuesta no incluye X-Content-Type-Options: nosniff.

Recomendación: Agrega X-Content-Type-Options: nosniff en API gateway/backend.

12. Falta Referrer-Policy (LOW)

Estado: Persistente | CWE: CWE-16

Endpoint: <https://urs.qa.vettica.co/>

Descripción: No se encontró cabecera Referrer-Policy en la respuesta del API.

Recomendación: Configura Referrer-Policy estricta (p. ej., no-referrer).

13. Validación manual requerida: BOLA/IDOR por objeto (LOW)

Estado: Persistente | CWE: CWE-639

Endpoint: https://urs.qa.vettica.co

Descripción: Este control requiere pruebas autenticadas diferenciales y contexto de negocio.

Recomendación: Ejecuta pruebas con dos identidades y cruza IDs para detectar acceso indebido a recursos de terceros.

14. Validación manual requerida: BFLA por rol (LOW)

Estado: Persistente | CWE: CWE-285

Endpoint: https://urs.qa.vettica.co

Descripción: Este control requiere pruebas autenticadas diferenciales y contexto de negocio.

Recomendación: Prueba endpoints de privilegio alto con cuentas de menor rol y verifica denegación consistente.

15. Validación manual requerida: Mass Assignment (LOW)

Estado: Persistente | CWE: CWE-915

Endpoint: https://urs.qa.vettica.co

Descripción: Este control requiere pruebas autenticadas diferenciales y contexto de negocio.

Recomendación: Intenta campos no permitidos en payloads (role, status, flags internos) y valida whitelists server-side.

16. Validación manual requerida: JWT claims/TTL/revocación (LOW)

Estado: Persistente | CWE: CWE-613

Endpoint: https://urs.qa.vettica.co

Descripción: Este control requiere pruebas autenticadas diferenciales y contexto de negocio.

Recomendación: Verifica exp/iat/nbf/aud/iss/jti, rotación de claves y revocación de tokens.